

Cybersecurity Incident Case Study Title

Prepared by

Akomolafe Olumide 9076433

Case Studies in Cybersecurity Response Planning

1 Incident overview and timeline

Executive summary

In June 2024, CDK Global, a dealer-management software (DMS) vendor used by around 15,000 car dealers in North America, suffered two ransomware attacks carried out by the BlackSuit hackers within a period of 24 hours which virtually brought its platform down to a halt. Dealers returned to using manual ways of working with pen and paper for almost two weeks. Several sources say that CDK paid a ransom of approximately \$25 million in Bitcoin to finally restore its system. The estimated losses for the dealers amounted to over \$1 billion, which is a good example of how a single hacked software vendor can cause massive disruptions for the whole industry.

Incident context and scope

- Organization/sector: CDK Global - A cloud-hosted software provider of automobile management solutions for the North American industry.
- Date/time: Initial breach took place between June 18 and June 19, 2024 (reported around 2.00 AM on June 19), and the second breach took place on June 19, 2024.
- Location/environment: CDK data centers and the VPN connections of dealerships to obtain services from CDK.
- Category/severity: A ransomware attack with the probability of double-extortion from the BlackSuit syndicate (previously known as Royal and affiliated with the Conti syndicate). Critical as around 15,000 dealerships are affected (BreachLock, 2024; Fischer, 2024)
- Affected systems/data: DMS software tools, telephone systems, and customer-support systems were not accessible. Some sources mention the potential exposure of sensitive information, including SSNs, bank account numbers, and other market data, although the company has never confirmed this information (Keeper Security, 2024).

Key events

Select four to six events that explain detection, response and outcome. Cite the source for each event; distinguish the occurrence date from the discovery date.

Date and time	Event and action	Source
Jun. 18–19, 2024	First ransomware attack was detected, leading CDK to begin a shutdown of its IT infrastructure, communications, and applications.	Centraleyes, 2024; TechTarget
Jun. 19, 2024	A second cyberattack took place while recovering from the first one, causing CDK to stop operations once again.	BreachLock, 2024
Jun. 21, 2024	Approximately 387 btc (about US\$25 million) was sent over to a wallet connected to the BlackSuit group, which is suspected of being used to pay for ransom.	Lyngaas, 2024;
Jun. 24, 2024	CDK warned the dealers that the problems might persist until June 30; a report has been made regarding the connection between BlackSuit and the attack.	Fischer, 2024
Jun. 28 – Jul. 4, 2024	Phased restoration started with July 4 as the target for full restoration; initially, CDK plans to restore systems for smaller dealers first.	BlackFog, 2024
Jul. 19–21, 2024	The company successfully repels another attack while still reinforcing its systems and warns dealers of impostors posing as CDK service representatives.	BreachLock, 2024

2 Evidence and incident analysis

The report by CDK has not been made available in the public domain. The only information is taken from CDK's own notifications to customers, the blockchain tracking reported by CNN (Lyngaas, 2024) and the articles on threats citing the Recorded Future expert Allan Liska (Fischer, 2024) and the experts from cybersecurity companies (BreachLock, BlackFog, Centraleyes, Dirox). The key points validating the classification of ransomware/double extortion are the emergency shutdown of the IT systems across the whole company, the identification of a cryptocurrency transferred to the wallet connected to BlackSuit affiliates and another intrusion during recovery suggesting the fact that the previous intrusion has not been completely eradicated.

Root cause and contributing factors

CDK has not provided the data regarding the first invasion vector for the attack on the network. However, according to the industry experts (Dirox 2024), the attackers used a credential dump to penetrate the system, but it was not clear which method was used to approach CDK's platform (it is a fact that dealers are connected to the CDK's system through a continuous, always on VPN), which is yet another factor that needs constant oversight and control to minimize risk of compromising a single account/ endpoint leading to disastrous consequences.

Business impact and reporting considerations

Financially: the ransom amount the attackers asked for increased from an initial \$10 million to more than \$50 million before a sum of about \$25 million in Bitcoin was reported to have been paid on June 21 (Lyngaas, 2024; Digital Dealer, 2024). The independent consulting company Anderson Economic Group calculated the total amount of losses estimated at approximately \$1.02 billion for the period of three weeks affected by this event (Anderson Economic Group, 2024).

Operational: roughly 15,000 dealers throughout the U.S. and Canada lost access to sales, finances, service, and inventory for almost two weeks, reverting to manual work.

Reputational: the CEO of CDK made a public commitment to compensate all affected dealers while the incident received lots of attention from the media on the national level. No public breach notification or regulatory filing was announced, as CDK is a privately held company.

3 Response and critical evaluation

Containment, eradication, and recovery

Stage	Documented action	Outcome or limitation
Containment	All IT systems, telephones, and applications were shut down immediately after each intrusion was detected.	Prevented additional spread but left ~15000 retailers without core systems for almost two weeks. (Centraleyes, 2024)
Eradication	Details of the process remain undisclosed; however, it most certainly involved negotiations (involving ransom payment) and rebuilding of the affected systems.	A second attack in the recovery process (June 19) indicated that elimination efforts after the initial incident had failed. (BreachLock, 2024)
Recovery	All operations resumed in phases, starting from June 28 with smaller dealers and ending by July 4, with later updates about scams exploiting the attacks.	The overall recovery process took a considerable longer time than planned and social engineering attacks after the incident took place up until the end of July. (BreachLock, 2024)

Evaluation of the response

- Strength: speedy shutdown upon identifying the breaches possibly curtailed the magnitude of data encrypted and further damage inflicted once the breaches were detected.
- Downside: the occurrence of another breach at the time of recovery signifies that termination and fortification measures were not enough to close the avenues of attack of malicious actors prior to the connection of the systems.
- Weakness: dependence on the ransom payment that made the recovery possible indicates a lack of independence in recovery (for instance, there are no reports of successful implementation of backups) and has financed a criminal organization without any promise of saving it from another ransomware attack.

Alternative actions and tradeoffs

There are two alternative actions that must be weighed. First, restoring the isolated tested backups rather than paying the ransom would have spared the offenders from the financing they required, but it would likely necessitate a longer downtime due to the large number (15,000) of dealer sites and the possibility of malfunctioning backups or lack of availability of the backups — the reality that might explain the option chosen; however, in hindsight, considering the consequences faced, the second option chosen does not seem that reasonable. Second, building dealer accesses in a way of having isolated and individual tenants rather than using a commonVPN solution would eliminate the far-reaching consequences of having a compromised account, even though the solution would be much more complicated and complex.

4 Lessons, recommendations and references

Lessons learned and conclusion

- The action of any compromised SaaS service provider has the potential to affect the whole of an industry if several firms utilize the same platform, and concentration risk deserves to be governed in an appropriate manner (ISPartners, 2024)..
- Before linking systems together again, complete eradication has to be confirmed through reliable means instead of just being assumed. If systems get compromised again during restoration, it is a testament that containment was declared in a rush.
- High-value target remote-access lines with a constant connection, such as dealer VPN, must be given the same protection measures as the core network.

Prioritized recommendations and Conclusion

Give two or three specific improvements linked to the identified causes or response gaps. Include longer-term improvement where justified.

Priority and action	Responsible role and timing	Success measure
Make sure eradication can be confirmed independently (through credential alteration, reimaging endpoints, and checking the access	CISO/Information Security; Term - short (0 - 1 month, prior to restoration)	Restoration process occurs without incident; confirmation of clean

log) before reconnecting or reinstating access for clients.		systems obtained before reconnection.
Invent a new connectivity system for multi-tenant dealerships based on divided zero trust access and mandatory multifactor authentication instead of constant VPN access.	IT Infrastructure/Security Architecture; Term -short and moderate (1 - 6 months)	All dealer connections moved to segmented and MFA-protected access; no shared credential possible between tenants.
Keep an efficient backup system that is tested regularly and that has a solid incident response/business continuity plan to decrease the need for ransom payments.	CISO/Management - Term - moderate and long (3 -12 months)	Quarterly backup and restore exercises conducted successfully; resolution acceptable to company management.

Collectively, these three initiatives directly remedy the response shortcomings noted in this case: the unverified eradication prior to recovery, a vague and weakly partitioned out-of-band model, and the overreliance on ransom payment without testing backup and recovery as a viable alternative. Confirming eradication and using segregation and zero-trust techniques would most appropriately help minimize the likelihood and consequences of this particular attack, while using tested backups and rehearsal of IR would ensure a permanent and long-term improvement preventing a need to pay the attackers again in the future.

References

- Anderson Economic Group. (2024, July 15). Dealer losses due to CDK cyberattack reach \$1.02 billion. <https://www.andersoneconomicgroup.com/dealer-losses-due-to-cdk-cyberattack-reach-1-02-billion/>
- BlackFog. (2024). CDK Global ransomware: What happened and how it impacted businesses. <https://www.blackfog.com/cdk-global-ransomware-attack/>
- BreachLock. (2024). Ransomware attack on CDK Global cripples US automotive dealerships. <https://www.breachlock.com/resources/advisories/ransomware-attack-on-cdk-global-cripples-us-automotive-dealerships/>
- Centraleyes. (2024). Explainer: The CDK Global ransomware attack. <https://www.centraleyes.com/explainer-the-cdk-global-ransomware-attack/>

- Digital Dealer. (2024, July 15). Report: CDK paid \$25 million to end ransomware attack.
<https://digitaldealer.com/dealer-gm/report-cdk-paid-25-million-to-end-ransomware-attack/>
- Dirox. (2024). CDK cyber attack: Understanding and preventing future threats.
<https://dirox.com/post/cdk-cyber-attack-understanding-and-preventing-future-threats>
- Fischer, S. (2024, June 24). BlackSuit ransomware linked to auto dealers' outages. Axios.
<https://www.axios.com/2024/06/24/blacksuit-ransomware-cdk-global>
- ISPartners. (2024). CDK Global: Lessons from the car dealership cyberattack.
<https://www.ispartnersllc.com/blog/car-dealership-cyberattack/>
- Keeper Security. (2024, July 17). What to know about the 2024 CDK Global ransomware attack. <https://www.keepersecurity.com/blog/2024/07/17/what-to-know-about-the-cdk-global-ransomware-attack/>
- Lyngaas, S. (2024, July 11). How did the auto dealer outage end? CDK almost certainly paid a \$25 million ransom. CNN. <https://kvia.com/news/business-technology/cnn-business-consumer/2024/07/11/how-did-the-auto-dealer-outage-end-cdk-almost-certainly-paid-a-25-million-ransom/>
- TechTarget. (2024). The CDK Global outage: Explaining how it happened.
<https://www.techtarget.com/whatis/feature/The-CDK-Global-outage-Explaining-how-it-happened>